

Critical:

C1: Weak Administrator Password

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1110.003: Password Spraying	
	Mitigations	M1036: Account Use Policies M1032: Multi-Factor Authentication M1027: Password Policies	
		Affected Scope	

Description

The affected host's admin local user account was found to be using a weak password that was successfully guessed using a dictionary-based brute force password attack. This led to compromise of the admin account.

Business Impact

This vulnerability can lead to operational disruptions, as an attacker with administrative privileges on the host can disrupt systems.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. Implement and enforce a strong password policy for all accounts to ensure attackers are unable easily brute force passwords. As a baseline the following minimum password policy is recommended:
 - a. Minimum of 12 characters

- b. At least one uppercase character, one lowercase character, one digit character, and one special symbol.
 - c. Unique passwords for each user and service to prevent password reuse
2. Implement a lockout policy to block attackers after repeated failed login attempts, preventing them from brute forcing credentials.
3. Implement multi-factor authentication to prevent access even with leaked or disclosed passwords.

References

[DigiCert - Creating Password Policy Best Practices](#)

[Linode - Fail2Ban for SSH Brute-force Protection](#)

[Palo Alto Networks - Multi Factor Authentication](#)

C1: Administrator/Root Password Reuse

Matrix Calculation		CVSS Score	Risk
Impact	Critical	10.0	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H</u>	
MITRE ATT&CK	Techniques	<u>TA0006: Credential Access</u> <u>T1078: Valid Accounts</u> <u>T1078.002: Domain Accounts</u> <u>T1110.003: Password Spraying</u>	
	Mitigations	<u>M1036: Account Use Policies</u> <u>M1032: Multi-Factor Authentication</u> <u>M1027: Password Policies</u>	
Affected Scope			

Description

The affected host's admin local user account was found to be using the same password across multiple services and machines, including service 1 and service 2.

Business Impact

Having login access to the affected host's admin local user account allows the attacker to have administrator privileges on affected hosts, giving them access to private customer and business data, as well as modify and take down company services.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. Implement a strong password policy that prohibits reused passwords across multiple accounts or services.
2. Implement multi-factor authentication to prevent access even with reused passwords.
3. Utilize a password manager to incentivize employees to not reuse passwords.
4. Train all users on the risk of password reuse

References

[CISA - Password Manager Guidelines](#)

[Palo Alto Networks - Multi Factor Authentication](#)

C1: Lack of Host-Based Firewall

Matrix Calculation	CVSS Score	Risk
--------------------	------------	------

Impact	Critical	N/A	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK		T1595: Active Scanning	
		M1056: Compromise	
		M1037: Filter Network Traffic	
Affected Scope			

Description

Multiple machines within APT's network are operating without any host-based firewalls or access control list (ACL) protections. The absence of host-based firewalls increases the attack surface, allowing for machine enumeration, unauthorized access, and exploitation of vulnerable services.

Business Impact

The lack of network protection leaves the business open for attackers to exploit any vulnerabilities on the affected machines. If they gain access to the internal network, they will be able to cause significant damage to APT's operational functionality and lead to the loss of sensitive data.

Steps to Reproduce

1. Run nmap on the network to enumerate services
Nmap -sV -sC 10.0.0.0/24 --min-rate 5000

Remediations

Team-XX recommends the following:

1. Implement host-based firewalls on all machines to only allow connections to public facing services. Custom firewall rules will need to be implemented for services that are not public facing but need to be accessed by other machines by configuring the source IP address to correspond to the machines on the local network.

2. Use iptables, ufw, or firewalld for linux-based machines.
3. Use the built-in windows firewall for windows-based machines.

References

[NIST Guidelines on Firewalls and Firewall Policy](#)

[Phoenixnap - Configuring Firewall with UFW on Ubuntu](#)

[Microsoft - Firewall and Network Protection](#)

C1: Server-Side Template Injection in KEY website

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1059: Command and Scripting Interpreter	
	Mitigations	M1038: Execution Prevention M1050: Exploit Protection M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

The affected website was found to not properly sanitize user input when rendering with the jinja2 templating engine, making it vulnerable to a Server-Side Template Injection attack. This vulnerability allows an attacker to execute arbitrary python code on the website server.

Business Impact

This allows an attacker to gain control of the website along with all of the data the website hosts. This can lead to sensitive data being leaked, violating certain data protection laws.

Steps to Reproduce

1. Find website with search input
2. Input `{{7*7}}` and find the output to be 49, showing that it executed the code
3. Input `{{ self._TemplateReference__context.cycler.init_globals.os.popen('id').read() }}` to run arbitrary shell commands on the machine

Remediations

Team-XX recommends the following:

1. Utilize `the templating engine's` built in `render_string` function instead of `render_string` function to ensure that the input is properly sanitized
2. Utilize a web application firewall to block dangerous requests.
3. Sandbox the application and restrict its permissions to avoid remote command execution on the server.

References

[Jinja2 API Documentation for User Sanitization](#)

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

C1: Zerologon

Matrix Calculation		CVSS Score	Risk
Impact	Critical	10.0	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
	Techniques	T1210: Exploitation of Remote Services	

MITRE ATT&CK	Mitigations	M1030: Network Segmentation M1051: Update Software M1016: Vulnerability Scanning
Affected Scope		

Description

The affected host contains a critical flaw in its version of the Netlogon Remote Protocol service, noted as CVE-2020-1472. This vulnerability allows an unauthorized attacker to gain administrative control of the domain controller.

Business Impact

This allows an attacker to gain control of every machine that is joined to the domain controller. This poses serious threats to data protection and sensitive information on any domain joined machine. It can also cause significant downtime to business systems, disrupting productivity.

This allows an attacker who has discovered the root password to access every single machine on the network, allowing them to access any user/client's information. It also allows them to **modify the company's web pages and other key services.**

Steps to Reproduce

1. Launch Metasploit - msfconsole
2. Search for Zerologon exploit – search zerologon
3. Load Exploit Module – use 0
4. Set LHOST to the attack machine's IP and set RHOSTS to the Domain Controller that is being attacked.
5. Run the exploit - run

Note: **Team-XX** did not fully exploit the Zerologon vulnerability, as this attack is known to cause harm to the production environment by setting the domain Admin password to blank, introducing new vulnerabilities in the network.

Remediations

Team-XX recommends the following:

1. Apply the Microsoft security updates released after February 2021 and install on all vulnerable Domain Controllers as soon as possible to protect against the ZeroLogon exploit. This patch requires an update and restart to the machine and may not be applicable if X is a critical system.
2. Block inbound traffic for TCP port 135 on the network firewall and monitor for malicious activity in the domain controller security event logs for signs of exploitation such as Event ID 4742.
3. Implement Windows Defender or another Antivirus solution to detect and prevent common AD attacks.

References

[CrowdStrike - ZeroLogon Security Advisory](#)

[Microsoft - ZeroLogon Security Patch](#)

[NIST - CVE-2020-1472](#)

C1: Eternal Blue

Matrix Calculation		CVSS Score	Risk
Impact	Critical	10.0	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H</u>	
MITRE ATT&CK	Techniques	<u>T1210: Exploitation of Remote Services</u>	
	Mitigations	<u>M1030: Network Segmentation</u>	
		<u>M1051: Update Software</u> <u>M1016: Vulnerability Scanning</u>	
Affected Scope			

Description

The host contains a critical flaw in its version of the Server Message Block (SMB), by running an out-of-date version, SMBv1, denoted as CVE-2017-0144. This vulnerability allows an unauthorized attacker to gain administrative control of the **domain controller/windows server** by sending specially crafted network packets to cause an out-of-bounds memory corruption error and run code at an elevated privilege.

Business Impact

This vulnerability allows an attacker to gain full control of the server. This poses serious threats to data protection and sensitive information stored on the machine. It can also cause significant downtime to business systems, disrupting productivity. It also allows attackers to modify the company's web pages and other key services.

Steps to Reproduce

1. Launch Metasploit – msfconsole
2. Search for Zerologon exploit – search eternalblue
3. Load Exploit Module – use 0
4. Set LHOST to the attack machine's IP and set RHOSTS to the **Windows Server/DC** machine that is being attacked.
5. Run the exploit - run

Remediations

Team-XX recommends the following:

1. Apply the Microsoft security patch, MS17-010, and install it on all vulnerable Windows systems as soon as possible. This patch requires an update and restart to the computer and therefore may not be a viable option if **X** is a critical system.
2. SMBv1 should be disabled on affected machines as soon as possible and upgraded to SMBv3. The protocol is deprecated and contains known security weaknesses, including being the main cause of the EternalBlue exploit.
3. Block inbound traffic for TCP ports 139 and 445 on both the host-based and network firewall. Access to these ports should be restricted between

internal network segments, allowing communication only between machines and subnets that have a legitimate need for SMB.

References

[SentinelOne - EternalBlue Security Primer](#)

[NIST - CVE-2017-0144](#)

C1: noPac

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1068: Exploitation for Privilege Escalation	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

An attacker with access to any standard domain user can elevate their privileges to Domain Administrator by exploiting flaws in the Kerberos protocol and the Security Account Manager (SAM) in regards with name checking. This vulnerability allows an attacker to gain administrative control over the Domain Controller. This exploit takes advantage of two publicly disclosed vulnerabilities, CVE-2021-42278 and CVE-2021-42287.

Business Impact

Successful exploitation leads to a full domain compromise, with the attacker gaining complete control over the entire Active Directory Forest. They can steal

all credentials, deploy malware, exfiltrate or destroy sensitive data, and take over all domain-joined systems and services running on those systems.

Steps to Reproduce

Step 1: Use the noPac exploit found on Github: <https://github.com/Ridter/noPac>

Step 2: Input valid credentials and get a domain administrator shell.

OR

Step 1: Create a new machine account on the domain

Step 2: Rename the machine account's SAMAccountName to match a domain controller's name, without the ending '\$'.

Step 3: Request a Kerberos Ticket Granting Ticket (TGT) for the account

Step 4: Use this ticket to request a service ticket, which will have Domain Admin privileges, allowing for a takeover of the Domain Controller.

Remediations

Team-XX recommends the following:

1. Install security updates released by Microsoft in November 2021 or later for all Domain Controllers.
2. Change the Active Directory attribute MS-DS-MachineAccountQuota to zero to prevent non-privileged users from adding new machine accounts.
3. Implement Windows Defender or another Antivirus solution to detect and prevent common attacks.

References

[Secureworks - noPac Vulnerability Overview](#)

[Microsoft - CVE-2021-42278](#)

[Microsoft - CVE-2021-42287](#)

C1: Cleartext Credentials in Files

Matrix Calculation	CVSS Score	Risk
--------------------	------------	------

Impact	Critical	9.2	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:N/SC:H/SI:H/SA:N	
MITRE ATT&CK	Techniques	T1552: Unsecured Credentials - Credentials in Files	
	Mitigations	M1047: Audit M1022: Restrict File and Directory Permissions	
Affected Scope			

Description

System/Application contains the credentials of other users stored in plaintext, located in a file on the **Desktop**.

Business Impact

Having insecurely stored credentials on the system without any proper form of encryption can lead to personal information leakage and potential privilege escalation depending on the privileges of the compromised accounts. Since credential reuse is also a common vulnerability, an attacker could potentially move laterally across the network and compromise other accounts as well.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. All sensitive user credentials must be securely stored in appropriate, protected locations and never in unsecured files.
2. All sensitive data should be encrypted at rest to protect confidentiality, integrity, and prevent unauthorized access.

References

[NIST - Data Confidentiality: Identifying and Protecting Assets Against Data Breaches](#)

C1: JuicyPotato

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1068: Exploitation for Privilege Escalation	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

JuicyPotato is a Windows privilege escalation exploit that abuses the “SeImpersonate” and “SeAssignPrimaryToken” privileges to escalate from a **local service account** to System. The exploit impersonates Component Object Models (COM) to create new processes and assign its token to have system privileges.

Business Impact

If this exploit is present, it provides an easy route for attackers that get low-level access to the machine to elevate themselves to SYSTEM. With SYSTEM permissions, the attacker can access any confidential data or stored credentials on the machine, deface any running services, and move laterally to other machines that interact with the affected machine.

Steps to Reproduce

Step 1: Check if the **current service account** has “SeImpersonate” and “SeAssignPrimaryToken” privileges:

```
*codeblock? whoami /priv
```

Step 2: Transfer JuicyPotato.exe to the target system from

<https://github.com/ohpe/juicy-potato>

Step 3: Find a working CLSID for the target OS version from the JuicyPotato repository

Step 4: Execute the exploit

```
JuicyPotato.exe -l 1337 -p c:\windows\system32\cmd.exe -a "/c whoami > C:\output.txt" -t * -c {CLSID}
```

Step 5: Check the output file to confirm SYSTEM-level access:

```
type C:\output.txt
```

Expected output: nt authority\system

Remediations

Team-XX recommends the following:

1. Apply the latest Windows security patch, which will address several Potato-style exploits.
2. Service accounts should also not be given the "SeImpersonate" or "SeAssignPrimaryToken" privileges unless necessary.
3. If DCOM is not necessary, it should be disabled or removed.
4. In systems where these protections cannot be done, the network should be sufficiently segmented to prevent lateral access and suspicious impersonation techniques should be properly logged.
5. Implement Windows Defender or another Antivirus solution to detect and prevent common AD attacks.

References

[Microsoft Learn - Behavior Blocking Containment, Juicy Potato](#)

C1: Command Injection

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1190: Exploit Public-Facing Application</u> <u>T1203: Exploitation for Client Execution</u>	
	Mitigations	<u>M1038: Execution Prevention</u> <u>M1050: Exploit Protection</u> <u>M1048: Application Isolation and Sandboxing</u>	
Affected Scope			

Description

Command injection is a vulnerability that allows an attacker to execute arbitrary operating system (OS) commands on the system running the application. This occurs when the application uses user-supplied data in a command that is then executed by the system shell.

Business Impact

A successful command injection attacker could lead to a full compromise of the server hosting the application. They could view, modify, and steal sensitive information stored on the server and use the server to move laterally across the network.

Steps to Reproduce

Step 1: Identify the application feature **X** that passes user input to a system command.

Step 2: In the input, enter a valid value followed by a command separator (**X**).

Step 3: Append the OS command **'whoami'** after the separator and submit the input

Step 4: View the output **X** which will confirm the vulnerability.

Remediations

Team-XX recommends the following:

1. Avoid OS command execution and refactor the code to use APIs instead of calling out to OS commands.
2. If calling OS commands is unavoidable, use a whitelist of approved characters or blacklist of disapproved characters and reject any input that fails the check.
3. Utilize a web application firewall to block dangerous requests.
4. Sandbox the application and restrict its permissions to avoid remote command execution on the server.

References

[OWASP - Command Injection](#)

[PortSwigger - What is command injection?](#)

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

C1: ADACS Misconfigured Certificate Template – ESC1

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.4	Critical
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1648: Steal or Forge Authentication Certificates	
	Mitigations	M1015: Active Directory Configuration M1047: Audit	
Affected Scope			

Description

ESC1 is a misconfiguration in a certificate template within APT's Active Directory Certificate Services (ADCS). This vulnerable template allows a low privileged user to authenticate as the domain administrator, gaining privileged access to APT's domain.

Business Impact

Successful exploitation of ESC1 will allow threat actors to exfiltrate sensitive data from the domain and disrupt cruise operations by taking down critical domain systems, possibly leading to a loss of life.

Steps to Reproduce

Step 1: Identify vulnerabilities within the certificate templates:

```
certipy find -username john@corp.local -password Passw0rd -dc-ip 172.16.126.128
```

Step 2: Request a certificate to impersonate the Administrator user:

```
certipy req -username john@corp.local -password Passw0rd! -target-ip ca.corp.local -ca 'corp-CA' \ -template 'ESC1' -upn 'administrator@corp.local'
```

vStep 3: Use the certificate to log in as the Administrator user:

```
certipy auth -pfx administrator_cert.pfx -dc-ip 10.0.0.5
```

Remediations

Team-XX recommends the following:

1. Disable the "Supply in the Request" configuration.
2. Enable the "CA Manager Approval" requirement.
3. Remove any Extended Key Usage (EKU) properties that enable user authentication.
4. Restrict enrollment permissions to only trusted accounts.
5. Conduct regular audits of the ADCS system to identify any future misconfigurations.

References

[Microsoft - ESC1 Security Assessment and Prevention](#)

[CrowdStrike - Investigating ESC1](#)

C1: Lack of Multi-Factor Authentication

Matrix Calculation		CVSS Score	Risk
Impact	Critical	N/A	Critical
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1110: Brute Force	
	Mitigations	M1032: Multi-Factor Authentication	
Affected Scope			

Description

The APT network does not implement Multi-Factor Authentication (MFA) for user accounts. As a result, if an attacker can discover an account password, they will gain access to the network without any additional verification controls.

Business Impact

The absence of MFA significantly increases the danger of unauthorized access to APT's network. Successful compromise of an account can lead to data exfiltration, service disruption and jeopardization of operational integrity. A privileged account being compromised can endanger the entire network, including critical cruise operations, leading to severe safety risks and possible loss of life.

Steps to Reproduce

Step 1: Locate a user's credentials

Step 2: Authenticate with the user's credential, and notice that there is no additional verification required.

Remediations

Team-XX recommends the following:

1. Implement multi-factor authentication for all user accounts, prioritizing privileged accounts and any publicly available systems.
2. Monitor and audit authentication events for failed MFA verification or MFA bypass attempts.

References

[Palo Alto Networks - Multi Factor Authentication](#)

C1: Insecure Cookie Deserialization

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public Facing Application	
	Mitigations	M1048: Application Isolation and Sandboxing M1054: Software Configuration	
Affected Scope			

Description

The affected website deserializes Python pickled objects for cookie-based authentication of users. However, attackers can craft serialized payloads to trigger code execution on the host server.

Business Impact

This vulnerability can lead to operational disruption on the host server and a loss of critical data, as attackers can take full control of the machines.

Steps to Reproduce

- Step 1: Use the web browser's developer tools to extract the cookie.
- Step 2: Craft malicious pickled cookie to grant attacker a reverse shell.
- Step 3: Modify cookie with the developer tools and send new request to web browser.
- Step 4: Run netcat Listener and wait for reverse shell to spawn.

Remediations

Team-XX recommends the following:

1. Replace insecure pickled based cookie formats with cryptographically signed or encrypted alternatives such as JSON Web Tokens (JWT) or Flask's in-built session cookies.

2. Isolate the web application in a docker container to reduce impact if an attacker can achieve code execution on the target server

References

[Portswigger - Insecure Deserialization](#)

C1: PetitPotam

Matrix Calculation		CVSS Score	Risk
Impact	Critical	10.0	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1190: Exploit Public Facing Application	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

The affected host is vulnerable to CVE-2021-36942 (PetitPotam). This vulnerability forces the windows host to authenticate to an attacker controlled NTLM server, allowing the attacker to relay the authentication request to compromise the domain controller.

Business Impact

This vulnerability can lead to operational disruptions, as an attacker can take control of the domain, taking down critical infrastructure that APT needs for its business and cruise operations.

Steps to Reproduce

Step 1: Start an SMB server:

```
Impacket-smbserver share . -smb2support
```

Step 2: Run the petitpotam attack.

Step 3: Capture authentication request in the SMB server.

Remediations

Team-XX recommends the following:

1. Disable NTLM authentication on the Domain Controller
2. Disable NTLM authentication on ADCS servers using group policy.
3. Install Microsoft's Security updates addressing NTLM relaying issues

4. Enable SMB Signing to prevent NTLM relaying.

References

[Microsoft - Mitigating NTLM Relay Attacks on ADCS](#)
[Rapid7 - PetitPotam Security Advisory](#)

C1: Token Impersonation Privilege Escalation

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1068: Exploitation for Privilege Escalation T1134: Access Token Manipulation - Token Impersonation/Theft	
	Mitigations	M1026: Privileged Account Management	
Affected Scope			

Description

Token Impersonation on a Windows Server allows an attacker to steal another user's token running in the system's memory. If exploited, this allows an attacker with unauthorized access to a low-privileged account to laterally move to NT AUTHORITY\SYSTEM, giving the attacker full compromise on the server.

Business Impact

Given an attacker has access to a low privilege user on the Windows Server, they can pivot to a higher authority on the system. This allows the attacker to have full compromise on the server, resulting in complete compromise of the confidentiality, integrity, and availability of sensitive information and services on the network.

Steps to Reproduce

- Step 1: Obtain a Meterpreter shell on the vulnerable system
- Step 2: List the available Delegation Tokens using *list_tokens -u*
- Step 3: Impersonate NT AUTHORITY\SYSTEM using *impersonate_token "NT AUTHORITY\SYSTEM"*
- Step 4: Use the *shell* command to get a shell as the elevated user
- Step 5: Type *whoami* to verify elevated privileges

Remediations

Team-XX recommends the following:

1. Use Group Policy to restrict SeImpersonatePrivilege to only necessary, high-privileged users. Remove impersonated privileges from all service accounts and users that do not explicitly require it.
2. Configure LSA Protection via Group Policy and enable Protected Process Light (PPL) to protect LSASS process memory from unauthorized access

References

[Microsoft Windows - Access Tokens](#)

[Microsoft - Configure LSA Protection](#)

C1: Weak Database Password

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1110.003 - Brute Force: Password Spraying T1110.001 - Brute Force: Password Guessing	
	Mitigations	M1027: Password Policies	
Affected Scope			

Description

The Database password was found to be weak and guessable through brute force attacks, allowing an attacker to have control over the database.

Business Impact

This vulnerability can lead to operational disruptions and data leakage as an attacker that gains access to the database can view, modify, delete and add arbitrary data to the database.

Steps to Reproduce

Step 1: Run a brute force attack systematically guessing passwords.

Remediations

Team-XX recommends the following:

1. Implement and enforce a strong password policy for all accounts to ensure attackers are unable easily brute force passwords. As a baseline the following minimum password policy is recommended:
 - a. Minimum of 12 characters
 - b. At least one uppercase character, one lowercase character, one digit character, and one special symbol.

- c. Unique passwords for each user and service to prevent password reuse
- 2. Implement a lockout policy to block attackers after repeated failed login attempts, preventing them from brute forcing credentials.
- 3. Implement multi-factor authentication to prevent access even with leaked or disclosed passwords.

References

[DigiCert - Creating Password Policy Best Practices](#)